

BUSINESS REQUIREMENTS DOCUMENT

Module phân quyền CMS

Tài liệu yêu cầu nghiệp vụ gửi khách hàng xem xét và xác nhận trước khi triển khai đặc tả kỹ thuật.

Tên tài liệu	BRD – Module phân quyền CMS
Phạm vi	Phân quyền người dùng cho nhánh Hệ thống, Sự kiện và Di tích
Phiên bản	v1.0 Draft
Ngày soạn	12/05/2026
Trạng thái	Gửi khách hàng xem trước

Mục tiêu: thống nhất phạm vi nghiệp vụ, mô hình vai trò và nguyên tắc phân quyền giữa các bên trước khi đội phát triển thực hiện tài liệu đặc tả hệ thống chi tiết.

1. Mục đích tài liệu

Tài liệu này mô tả yêu cầu nghiệp vụ cho module phân quyền của hệ thống CMS, nhằm thống nhất cách hiểu giữa khách hàng, BA và đội phát triển trước khi triển khai.

BRD tập trung vào mục tiêu, phạm vi, vai trò người dùng, quy tắc nghiệp vụ và các luồng sử dụng chính; phần thiết kế kỹ thuật chi tiết như database schema, API và logic kiểm tra quyền sẽ được đặc tả ở tài liệu kỹ thuật riêng sau khi khách hàng xác nhận.

2. Bối cảnh nghiệp vụ

Hệ thống CMS phục vụ hai nhánh nghiệp vụ tách biệt là **Sự kiện** và **Di tích**. Mỗi nhánh có người dùng, dữ liệu và thao tác riêng, nên cần cơ chế phân quyền rõ ràng để người dùng chỉ thấy đúng phần việc thuộc trách nhiệm của mình.

Thiết kế phân quyền cần phản ánh nguyên tắc domain separation, tức là tách quyền truy cập theo miền nghiệp vụ; chỉ vai trò quản trị cao nhất mới được nhìn xuyên toàn hệ thống.

3. Mục tiêu nghiệp vụ

- Xác định rõ mỗi nhóm người dùng được xem và thao tác trên dữ liệu nào trong CMS.
- Tách biệt tuyệt đối nhánh Sự kiện và nhánh Di tích ở mức truy cập nghiệp vụ.
- Chỉ cho phép vai trò quản trị cao nhất truy cập xuyên nhánh và quản lý tài khoản toàn hệ thống.
- Cho phép triển khai nhanh giai đoạn đầu bằng bộ role cố định, có thể mở rộng đặc tả chi tiết ở giai đoạn sau.

4. Phạm vi giai đoạn 1

Trong phạm vi

- 5 role hệ thống cố định cho giai đoạn đầu.
- Quản lý truy cập menu, màn hình và thao tác nghiệp vụ theo role.

Ngoài phạm vi

- Tự cấu hình role động bởi người dùng cuối trên CMS ở giai đoạn 1.

- Tách biệt dữ liệu giữa nhánh Sự kiện và Di tích.
- Quản trị tài khoản ở mức hệ thống bởi SUPER_ADMIN.

- Thiết kế kỹ thuật chi tiết: DB schema, API, thuật toán phân quyền.
- Mô hình approval workflow nâng cao hoặc ma trận quyền chi tiết cấp field.

5. Nguyên tắc phân quyền

Rule 1 – Tách nhánh: Người dùng thuộc nhánh Sự kiện không được thấy chức năng hoặc dữ liệu của nhánh Di tích và ngược lại.

Rule 2 – Toàn quyền hệ thống: Chỉ SUPER_ADMIN có quyền nhìn xuyên toàn hệ thống và quản trị tài khoản.

Rule 3 – Tối thiểu quyền: Mỗi vai trò chỉ được cấp các quyền cần thiết để thực hiện nhiệm vụ được giao, phù hợp với best practice RBAC.

Rule 4 – Theo phạm vi được giao: Các vai trò nghiệp vụ chỉ thao tác trên dữ liệu “của mình” hoặc “được assign”, không mặc định nhìn thấy toàn bộ dữ liệu cùng nhánh.

6. Danh sách vai trò

Mã vai trò	Tên vai trò	Nhánh	Mô tả nghiệp vụ
SUPER_ADMIN	Quản trị hệ thống	Hệ thống	Toàn quyền trên toàn bộ hệ thống; tạo/khóa mọi tài khoản; xem toàn bộ dữ liệu; quản trị xuyên cả hai nhánh nghiệp vụ.
EVENT_OWNER	Chủ sự kiện	Sự kiện	Quản lý các sự kiện thuộc phạm vi sở hữu; CRUD sự kiện, vé và nhân viên của mình.
EVENT_STAFF	Nhân viên sự kiện	Sự kiện	Chỉ xem lịch và quét vé tại các sự kiện được assign; không quản trị dữ liệu cấu hình sự kiện.
HERITAGE_OWNER	Chủ di tích	Di tích	CRUD di tích, cụm và quản lý phạm vi di tích của mình; không truy cập nhánh Sự kiện.
CLUSTER_MANAGER	Quản lý cụm	Di tích	Chỉ sửa nội dung cụm được giao; không có quyền quản trị toàn bộ nhánh Di tích.

7. Ma trận quyền nghiệp vụ mức cao

Chức năng	SUPER_ADMIN	EVENT_OWNER	EVENT_STAFF	HERITAGE_OWNER	CLUSTER_MANAGER
Xem toàn bộ dữ liệu hệ thống	Có	Không	Không	Không	Không
Tạo / khóa tài khoản	Có	Không	Không	Không	Không
Gán vai trò cho người dùng	Có	Không	Không	Không	Không
CRUD sự kiện của mình	Có	Có	Không	Không	Không
CRUD vé của sự kiện mình	Có	Có	Không	Không	Không
Quản lý nhân viên sự kiện của mình	Có	Có	Không	Không	Không
Xem lịch sự kiện được giao	Có	Có	Có	Không	Không
Quét vé tại sự kiện được giao	Có	Có thể có theo nghiệp vụ	Có	Không	Không
CRUD di tích thuộc phạm vi mình	Có	Không	Không	Có	Không
CRUD cụm thuộc phạm vi mình	Có	Không	Không	Có	Không
Sửa nội dung cụm được giao	Có	Không	Không	Có	Có
Truy cập chéo sang nhánh khác	Có	Không	Không	Không	Không

8. Luồng nghiệp vụ chính

8.1. SUPER_ADMIN tạo tài khoản và gán vai trò

Quản trị viên hệ thống tạo mới tài khoản hoặc cập nhật tài khoản hiện có, sau đó gán vai trò phù hợp để người dùng chỉ thấy đúng chức năng tương ứng với role của mình.

8.2. EVENT_OWNER quản lý sự kiện

Chủ sự kiện truy cập module Sự kiện để tạo mới, chỉnh sửa hoặc xóa sự kiện, cấu hình vé và quản lý nhân viên của các sự kiện mình phụ trách.

8.3. EVENT_STAFF xem lịch và quét vé

Nhân viên sự kiện chỉ được xem các sự kiện được giao và thực hiện thao tác quét vé tại sự kiện đó; không được quyền thay đổi cấu hình sự kiện hoặc vé.

8.4. HERITAGE_OWNER quản lý di tích và cụm

Chủ di tích quản lý dữ liệu di tích và cụm trong phạm vi phụ trách, bao gồm tạo, sửa và xóa nội dung theo phạm vi được giao.

8.5. CLUSTER_MANAGER chỉnh sửa cụm được giao

Quản lý cụm chỉ truy cập và chỉnh sửa nội dung của những cụm được assign, không có quyền quản trị toàn bộ nhánh Di tích.

9. Các điểm cần khách hàng xác nhận

- Danh sách 5 vai trò ban đầu là phù hợp cho giai đoạn 1.
- Hai nhánh Sự kiện và Di tích tách biệt hoàn toàn; chỉ SUPER_ADMIN nhìn xuyên cả hai nhánh.
- EVENT_OWNER có quyền CRUD sự kiện, vé và quản lý nhân viên trong phạm vi sự kiện của mình.
- EVENT_STAFF chỉ xem lịch và quét vé tại sự kiện được assign.
- HERITAGE_OWNER có quyền CRUD di tích và cụm trong phạm vi phụ trách.
- CLUSTER_MANAGER chỉ sửa nội dung cụm được giao.
- Giai đoạn 1 chưa mở cơ chế tự cấu hình role động cho người dùng cuối trên CMS.

10. Bước tiếp theo sau khi xác nhận

Sau khi BRD được khách hàng xác nhận, đội dự án sẽ chuyển sang tài liệu đặc tả hệ thống chi tiết để phục vụ triển khai, trong đó mô tả permission chi tiết, dữ liệu, API, rule kiểm tra quyền và các ngoại lệ nghiệp vụ.

Tài liệu trình bày theo hướng BRD chuyên nghiệp với các thành phần phổ biến như mục tiêu, phạm vi, vai trò, requirements và xác nhận stakeholder, phù hợp với các mẫu BRD thực hành phổ biến.